

Relatório de Vulnerabilidade Crítica: Falha SEC-TC-F02

Exposição de Diretórios e Backups
via robots.txt

Alvo: **TechCorp Solutions**

Endereço IP: **98.95.207.28**

Status do Incidente: **Aberto**

Classificação de Risco: **Médio (CVSS 5.3 -
AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)**

Vetor Principal: **HTTP (Porta 80)**



A Vulnerabilidade

Arquivo de configuração de rastreadores (robots.txt) expõe o mapeamento completo da infraestrutura restrita.



O Vetor

Acesso via HTTP (Porta 80).
Leitura pública e não autenticada permitida a qualquer visitante.



A Consequência

Entrega um mapa do tesouro passivo. Facilita o reconhecimento direcionado por cibercriminosos sem disparar alarmes em sistemas tradicionais de defesa (WAF).

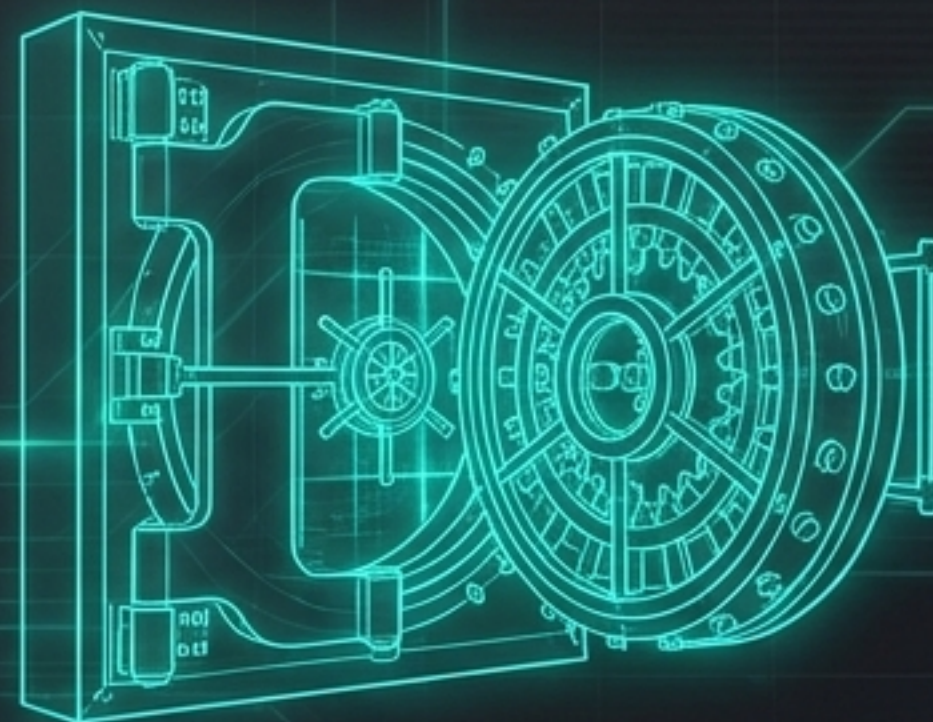
Segurança por Obscuridade



A Abordagem: Usar diretivas Disallow no arquivo robots.txt para tentar esconder diretórios sensíveis de motores de busca.

A Falha: O arquivo é inerentemente de leitura pública. Hackers e scanners automatizados (crawlers maliciosos) leem este arquivo como a etapa número um do processo de reconhecimento (Recon). Ocultar não é proteger.

Defesa em Profundidade



A Solução Real: O controle de acesso a recursos restritos deve ser garantido por mecanismos de autenticação robustos diretamente no servidor web e na aplicação web, recusando acesso no nível da arquitetura.


```
[Attacker@Kali]~# curl -s 'http://98.95.207.28/robots.txt'
```

O Mapa do Tesouro (Diretórios Vazados)

[/admin/]

-> Painel de controle e gerência.

[/backup/]

-> Arquivos mortos e dumps de dados históricos.

[/.git/]

-> Repositório de código-fonte e histórico de versionamento.

[/config/]

-> Arquivos estruturais e potenciais credenciais.

Disallow: /config/

FLAG{r0b0ts_txt_l34k4g3}

Arquivo de backup: /backup/database_backup_2024.sql

1

O Erro Humano: Uso de comentários (#) para deixar notas operacionais em um arquivo estático e público.

2

A Flag de Validação: Exposição direta da chave de integridade do laboratório (FLAG{r0b0ts_txt_l34k4g3}).

3

O Risco Crítico: Apontamento exato (URL completa) para o dump do banco de dados contendo dados de clientes, eliminando a necessidade de adivinhação por parte do atacante.

Cadeia de Ataque: Da Leitura à Exfiltração

Passo 1: Reconhecimento (Falha F02)

Ação: Atacante lê o robots.txt.

Resultado: Obtém o mapa da infraestrutura e a localização exata do banco de dados.

Passo 2: Bypass Passivo de WAF

Ação: O atacante não precisa usar ferramentas ruidosas como o Dirb ou Gobuster para escanear o servidor no escuro.

Resultado: Navega diretamente para os alvos, burlando gatilhos de segurança e bloqueios de IP.

Passo 3: Exfiltração de Dados

Ação: Download direto de `http://98.95.207.28/backup/database_backup_2024.sql`.

Resultado: Quebra total de confidencialidade (LGPD), vazamento de senhas e dados corporativos.

Fase de Remediação: Assumindo o Controle



A segurança não deve depender da ignorância do atacante. O foco imediato é remover as referências públicas e aplicar Hardening arquitetural no Servidor Apache. O controle de acesso será ditado pelo servidor, não por pedidos informais aos web crawlers.

Correção Nível 1: Limpeza de Metadados

Antes - Inseguro	Depois - Seguro
 <pre>User-agent: * Disallow: /admin/ Disallow: /backup/ Disallow: /.git/ Disallow: /config/ # FLAG{r0b0ts_txt_l34k4g3} # Arquivo: /backup/database_backup_2024.sql</pre>	 <pre>User-agent: * Disallow: /marketing/campanha-interna/ Allow: / User-agent: Googlebot Allow: /</pre>
<i>Nota: Exposição desnecessária de topologia interna e anotações operacionais.</i>	Nota: Remoção completa de caminhos sensíveis e arquivos soltos. O arquivo agora serve exclusivamente para indexação pública de SEO.

Correção Nível 2: Hardening do Servidor Apache

Contexto: Implementação de diretivas estritas de controle de acesso no arquivo de configuração raiz do servidor (/etc/apache2/sites-available/techcorp.conf).

Options -Indexes:

Desativa o **Directory Listing**. Impede que o servidor mostre uma lista de arquivos se não houver um index.html.

```
1 <Directory /var/www/html/backup>
2     Options -Indexes
3     Require all denied
4 </Directory>
5
6 <Directory /var/www/html/admin>
7     Options -Indexes
8     Require valid-user
9 </Directory>
10
```

Require all denied:

Bloqueio absoluto em nível de rede. Mesmo que o atacante descubra o diretório, o Apache retornará um Erro 403 (Forbidden).

Postura de Segurança e Próximos Passos



Ação Concluída

Mapeamento completo da vulnerabilidade **SEC-TC-F02**.

Higienização do arquivo **robots.txt** e remoção da flag (**FLAG{r0b0ts_txt_l34k4g3}**) e comentários **.sql** do ambiente público.



Próximos Passos Imediatos

Homologação das diretivas estritas no novo arquivo **techcorp.conf**.

Reinicialização do serviço em produção: **systemctl restart apache2**.

Auditoria interna para garantir a remoção definitiva do arquivo **database_backup_2024.sql** de qualquer diretório web-acessível.

Ocultar não é proteger. O acesso a recursos críticos deve ser verificado, autenticado e restrito por design.